National University of Computer and Emerging Sciences

School of Computing

CS3002: Information Security

Assignment 3

(Marked – Mid-2 Practice)

Instructor: Aqsa Khalid **Semester:** Fall 2026

Topics: Access Control, Database Security (SQL Injection), Malware, Public Key Infrastructure, Buffer Overflow, Cross-Site Scripting (XSS),User Authentication

Instructions

- This assignment must be **handwritten** on **separate sheets of paper**. Typed or printed answers will **not** be marked.
- Write your name, roll number and section at the top of **every** sheet, and staple the sheets together.
- Marks for each part are shown in square brackets at the right margin.
- For numerical questions, **show all working**; a final answer without working receives no credit.
- Answer in your own words. Copied or shared answers will be treated as plagiarism and given zero.
- Keep answers concise; where a question says "one line" or "one method", do not write more than that.

Question 1: Access Control [16 marks]

(a) The access control matrix of a small system is shown below. The rights are **O** = owner, **R** = read, **W** = write, **X** = execute, and "–" means no access.

Subject	report.docx	salary.xlsx	backup.sh
Ali	O, R, W	–	R, X
Sara	R	O, R, W	–
Omar	R, W	R	O, R, W, X

(i) Write down the Access Control List (ACL) of each object.

(ii) Write down the capability ticket of each subject.

(b) Refer to the matrix in part (a).

(i) Which representation, ACLs or capability tickets, makes it easier to answer *"Who can access* `salary.xlsx`*?"*, and which makes it easier to answer *"What can Omar access?"* Give a one-line reason for each.

(ii) Why must a capability ticket be unforgeable? Name **one** method used to achieve this.

(c) Role-Based Access Control (RBAC).

(i) In one or two sentences, state how a *strict* RBAC system differs from DAC in the way access rights are assigned to users.

(ii) An online movie store has three age groups of users (Adult, Juvenile, Child) and two fee plans (Premium, Regular). Its policy depends on *both* age group and fee plan. How many roles are needed under RBAC to express this?

(iii) The store now expands to 4 regions, each with its own content rules that apply to every combination of age group and fee plan. How many roles are needed now? In one sentence, explain why ABAC does not suffer from this growth.

(d) ABAC. A hospital enforces the following policy:

> *A user may read a patient record only if the user is a Doctor or a Nurse working in the* same department *as the record. Doctors may read records from anywhere at any time. Nurses may read records only from the hospital intranet and only between 08:00 and 20:00.*

The available attributes are: subject attributes `s.title`, `s.dept`; object attributes `o.type`, `o.dept`; environment attributes `e.network` (`intranet`/`internet`) and `e.time`.

(i) Write the policy rule as a Boolean function $f(s, o, e)$ of these attributes. Access is granted if f evaluates to true.

(ii) Using your rule, decide **Grant** or **Deny** for each request.

Req.	Subject	Record dept.	Network	Time
R1	Nurse, Cardiology	Cardiology	intranet	14:00
R2	Nurse, Cardiology	Cardiology	internet	10:00
R3	Doctor, Neurology	Cardiology	intranet	11:00
R4	Doctor, Cardiology	Cardiology	internet	23:00

(e) MAC. Classification levels are ordered *Unclassified* < *Confidential* < *Secret* < *Top Secret*. Every subject has a security label (clearance, set of categories) and every object has a label (classification, category). A subject may **read** an object only if

$$\text{clearance} \geq \text{classification} \quad \text{AND} \quad \text{object's category} \in \text{subject's category set.}$$

The labels are:

Subject	**Label**	**Object**	**Label**
Judy	(Top Secret, {Crypto, Nuclear})	O1	(Secret, Crypto)
Ahmed	(Secret, {Crypto})	O2	(Top Secret, Nuclear)
		O3	(Confidential, Satellite)
		O4	(Secret, Nuclear)

Decide whether read access is granted or denied for each request, with a brief reason (which condition fails, if any):

(1) Judy → O1 (2) Judy → O2 (3) Judy → O3
(4) Ahmed → O1 (5) Ahmed → O2 (6) Ahmed → O4

Question 2: Database Security: SQL Injection [16 marks]

(a) A login page builds its query by string concatenation:

```
query = "SELECT id, name FROM users WHERE email = '" + email
       + "' AND pwd = '" + pwd + "';"
```

(i) An attacker types `admin@uni.edu'--` in the email field and anything in the password field. Write the final query that is sent to the database. (Assume `--` starts an SQL comment.)

(ii) Explain why the attacker is logged in without knowing the password.

(iii) The attacker does not know any valid email address. Give an input for the email field that makes the query return *all* rows irrespective of the password, and write the resulting query. Name this type of in-band attack.

(b) A bookshop page runs the query below, where `<input>` comes directly from the user:

```
SELECT title, author FROM books WHERE genre = '<input>';
```

The database also contains a table `accounts(username, password)`.

(i) Write an input value that makes the page display every username and password alongside the books, and write the resulting query.

(ii) Why must the injected `SELECT` return the same number of columns as the original query?

(c) Identify the attack type used in each scenario. Choose from: *tautology, piggybacked query, UNION-based data exfiltration, illegal/logically incorrect query, blind injection, denial of service*. Justify each answer in one line.

(i) An attacker enters `laptop'; DELETE FROM orders; --` in a search box.

(ii) The attacker submits a single quote `'` in a form field and the site displays a detailed server exception that includes table and column names.

(iii) The site shows the same generic "Something went wrong" page for every database error. The attacker requests `items.php?id=7 AND 1=1` and then `items.php?id=7 AND 1=2`, and compares the two pages.

(iv) The attacker's input makes the database repeatedly compress, encrypt and hash every row of a table with thousands of rows, driving the database server's CPU to 100%.

(d) A Java servlet contains the following code:

```
String id = request.getParameter("id");
String q = "SELECT * FROM bugs WHERE bug_id = " + id;
Statement st = connection.createStatement();
ResultSet rs = st.executeQuery(q);
```

(i) Rewrite the code using a prepared (parameterized) statement. Assume `bug_id` is an integer.

(ii) With your fixed code, explain why the input `1234 OR TRUE` cannot change the structure (parse tree) of the query.

(e) (i) Why is blind SQL injection called "blind", and what does the attacker observe instead of query results?

(ii) Besides prepared statements, name **two** other countermeasures against SQL injection.

Question 3: Malware [10 marks]

(a) Identify the **most appropriate** malware type for each scenario. Choose from: *virus, worm, trojan horse, scareware, browser hijacker, logic bomb, backdoor, spyware, keylogger, ransomware, zombie (bot), rootkit, bootkit.*

(i) A program attaches its code to executable files on a USB drive. Each time an infected file is run on a new PC, it copies itself into other executables on that PC.

(ii) Malware scans the local network for machines with a vulnerable open port and copies itself to them without any user clicking anything. The network slows to a crawl.

(iii) A hidden background program records every key typed on a bank's login page and sends the log to a remote server.

(iv) After breaking into a server, an attacker installs tools that give permanent administrator access and hide the attacker's processes and files from the task manager and antivirus.

(v) Thousands of home computers silently obey a remote server and simultaneously flood a website with requests.

(vi) A user's browser homepage and search engine change on their own, and extra advertisements are injected into every web page.

(b) In one line each, distinguish a **virus**, a **worm** and a **trojan horse** in terms of how each gets onto a system and spreads.

(c) Why do most real-world malware samples not fit neatly into a single category? Give one example combination.

Question 4: Public Key Infrastructure [18 marks]

(a) MITM against public-key cryptography.

(i) Alice fetches Bob's RSA public key over an insecure channel, and Mallory controls the channel. Describe, step by step, how Mallory can read the messages Alice encrypts for Bob without either of them noticing.

(ii) Explain how a digital certificate defeats this attack.

(b) Certificates and signatures.

(i) List **four** pieces of information found in an X.509 certificate.

(ii) Describe how a CA produces the signature on a certificate (mention the hash and the key used).

(iii) Describe how a receiver verifies this signature. State which key is used, and what must already be stored on the receiver's system for verification to work.

(c) Chain of trust. A browser receives the certificate of `shop.example.com`. It was issued by *Intermediate CA X*, whose own certificate was issued by *Root CA R*. The browser's trust store contains only Root CA R's certificate.

(i) List, in order, the signature checks the browser performs and the public key used for each.

(ii) The trust store is a security-critical component. What could an attacker achieve if they could add their own CA certificate to a victim's trust store?

(d) Revocation timeline (numerical). A CA publishes a Certificate Revocation List (CRL) once every 24 hours, at 00:00. Consider the following events, all on the same Monday unless stated:

00:00	CRL n is published
09:00	A web server's private key is stolen (key compromise event)
15:00	The owner discovers the theft and sends a revocation request to the CA
17:00	The CA marks the certificate as revoked
00:00 (Tuesday)	CRL n+1 is published

Assume clients rely only on CRLs unless stated otherwise.

(i) For how many hours after the key compromise can the attacker's use of the stolen key go undetected by CRL-based clients (i.e. until CRL n+1 appears)?

(ii) How many of those hours pass *after* the CA has already revoked the certificate?

(iii) If clients instead query an OCSP responder that updates at the moment of revocation, how long is the window of exposure from the key compromise? Why can OCSP not reduce it to zero?

(iv) The certificate has a 47-day validity period and the key is stolen on day 10 of that period. If there is no revocation checking at all, what is the maximum number of days the stolen key can still be misused? How many days would it be for a 365-day certificate stolen on day 10?

(e) Give **two** drawbacks of CRLs and **two** problems with OCSP. Why must the OCSP responder's own certificate also be checked?

(f) What is the role of a Registration Authority (RA)? Does the RA sign the certificate? Explain who does.

Question 5: Buffer Overflow [10 marks]

The following code runs on a 32-bit machine (4-byte words). It checks a 4-digit PIN before granting access to a locked device.

```
void load_pin(char *);
void grant_access(void);
void backdoor(void);

void verify() {
    char pin[4];
    char input[4];

    load_pin(pin); // loads the correct PIN into 'pin'
    gets(input); // reads the user-entered PIN

    if (strncmp(input, pin, 4) == 0)
        grant_access();

    return;
}
```

The stack layout just before `verify()` returns is as follows (stack grows toward lower addresses):

Address	Contents
`0x7fff0070`	return address
`0x7fff006c`	`pin[0..3]`
`0x7fff0068`	`input[0..3]`

(a) Explain why the use of `gets(input)` introduces a security vulnerability in this program.

(b) You do not know the correct PIN. Provide a hexadecimal representation of an attack string for `input` that forces `strncmp()` to return `0`, so that `grant_access()` is called. `verify()` should still return normally afterward.

(c) The function `backdoor()` is located at address `0x00000421`. Construct a hexadecimal attack string that causes `verify()` to unconditionally transfer control to `backdoor()` instead of returning normally. Explain why your string achieves this.

(d) Name **two** run-time defense mechanisms (no source code changes required) that would make this exploit harder to execute, and briefly explain how each works.

Question 6: Cross-Site Scripting (XSS) [10 marks]

A web application called "QuickChat" has the following features:

- A search bar: the search term typed by a user is shown back on the results page as `Results for: <term>`, taken directly from the URL's query string.
- A public comment wall: comments are permanently saved to the server's database and displayed to every visitor who opens that page.

(a) Identify which feature is vulnerable to **Reflected XSS**. Explain step-by-step how an attacker would exploit it, including how the malicious script reaches and executes in a victim's browser.

(b) Identify which feature is vulnerable to **Stored XSS**. Explain step-by-step how an attacker would exploit it, including how the malicious script reaches and executes in a victim's browser.

(c) Every DOM-based XSS vulnerability requires two elements. Name both, and give one example of each.

(d) Explain the difference between validation and encoding as XSS defenses. Which should be applied inbound, and which outbound?

Question 7: User Authentication [10 marks]

(a) A company uses Kerberos for 4 different application servers. An employee uses each service 3 times a day. How many times per day will the employee's device interact with (i) the Authentication Server (AS), and (ii) the Ticket Granting Server (TGS)? Explain your reasoning.

(b) Differentiate between Repudiable and Non-repudiable authentication, as discussed in class. Give one example authentication factor for each.

(c) A fingerprint-based door lock uses a similarity-score threshold to decide access.

(i) Explain why no two biometric scans of the same person produce an identical template.

(ii) If the organization lowers the similarity threshold to reduce false rejections (FRR) of genuine users, what is the security trade-off? Explain using the FAR/FRR concept.

— End of Assignment —